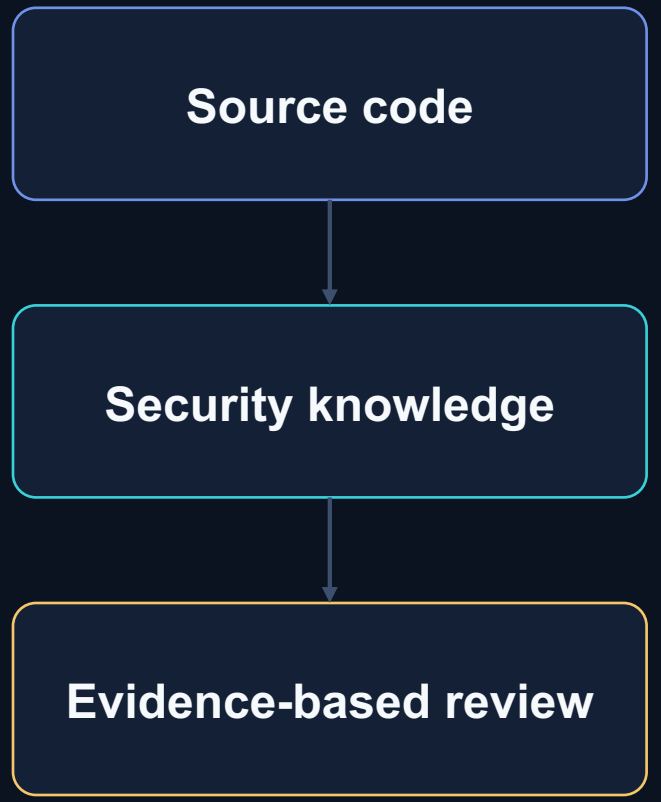
Danil Kovalev · Group VKB53

RAG for Secure Code

AI-Assisted Static Analysis in CI

Retrieval. Graphs. Agents.

How can external knowledge support vulnerability detection in CI?



Contents

1. **The problem** — Why security knowledge matters
2. **The pipeline** — RAG inside my CI module
3. **The evidence** — What Vul-RAG research reports
4. **Architecture** — GraphRAG, Agentic RAG, AG2 and FastMCP
5. **The value** — Costs, evaluation and conclusions

Why AI Code Review Needs Security Knowledge

Code alone may hide the security context.

CWE-89 · SQL injection

The product constructs all or part of an SQL command using externally-influenced input from an upstream component, but it does not neutralize or incorrectly neutralizes special elements that could modify the intended SQL command when it is sent to a downstream component. Without sufficient removal or quoting of SQL syntax in user-controllable inputs, the generated SQL query can cause those inputs to be interpreted as SQL instead of ordinary user data.

OWASP

Guidance and risk categories

CWE

Types of software weaknesses

CVE

Specific disclosed vulnerabilities

Use external knowledge to improve code review.

Sources: OWASP Top 10; MITRE CWE-89

How a Basic RAG Pipeline Works

Prepare the knowledge base



Analyze the code



Illustrative pseudocode

```
code = select_code()
query = describe_task(code)
evidence = retrieve(query)
finding = assess(code, evidence)
record(finding)
```

The retriever finds relevant passages.

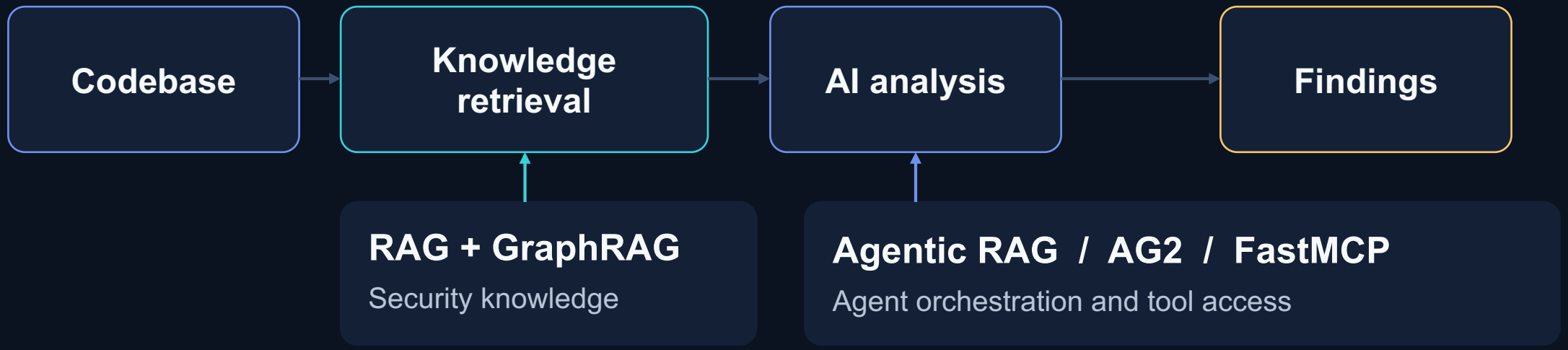
Relevant passages are added to the prompt.

Update documents separately from the model.

Sources: Lewis et al., 2020; Anthropic, 2024

My CI Security Module

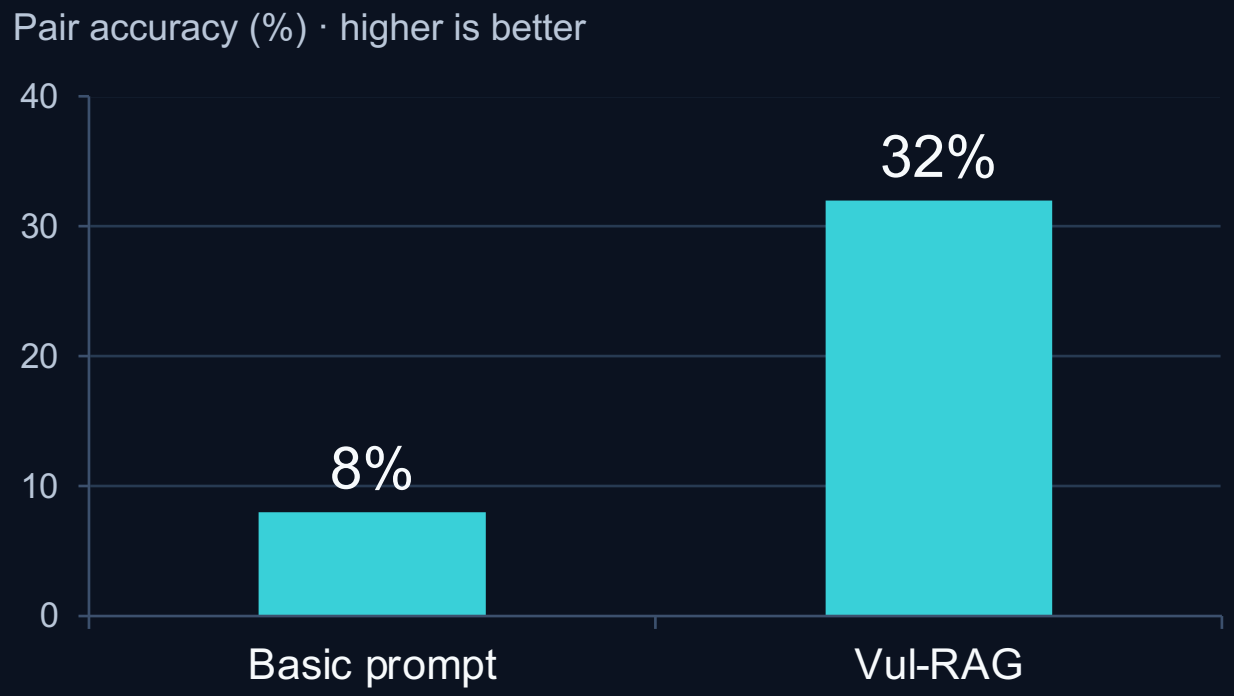
I developed a CI module for AI-assisted static analysis.



Knowledge collected from OWASP supports code analysis.

Research Evidence: Vul-RAG

GPT-4o on PairVul



586 function pairs · external benchmark

+24

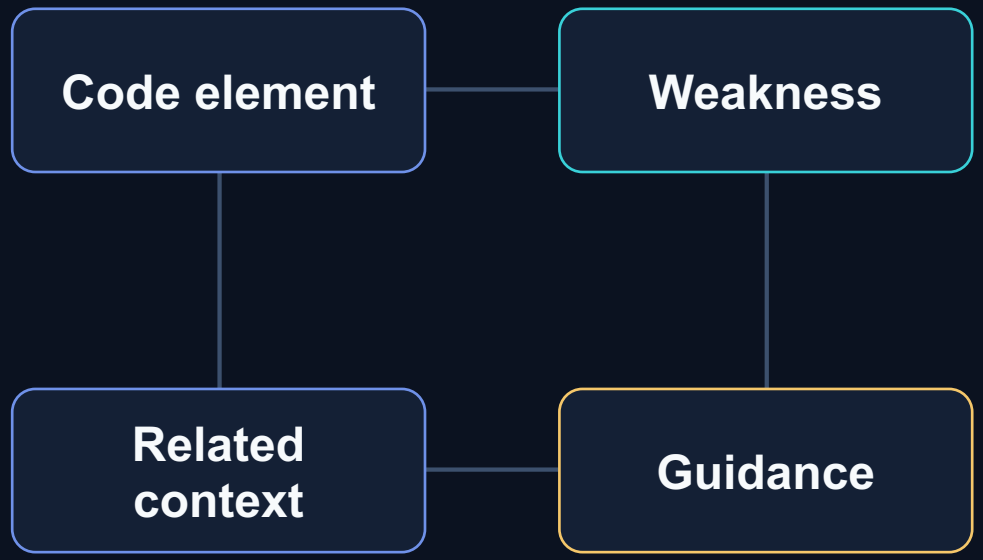
percentage points

Both versions must be classified correctly: vulnerable and patched.

Du et al., Vul-RAG, arXiv v3 (2025), Tables 1 and 4

GraphRAG: Connecting Related Facts

Retrieve relationships as well as passages.



Illustrative security-knowledge graph

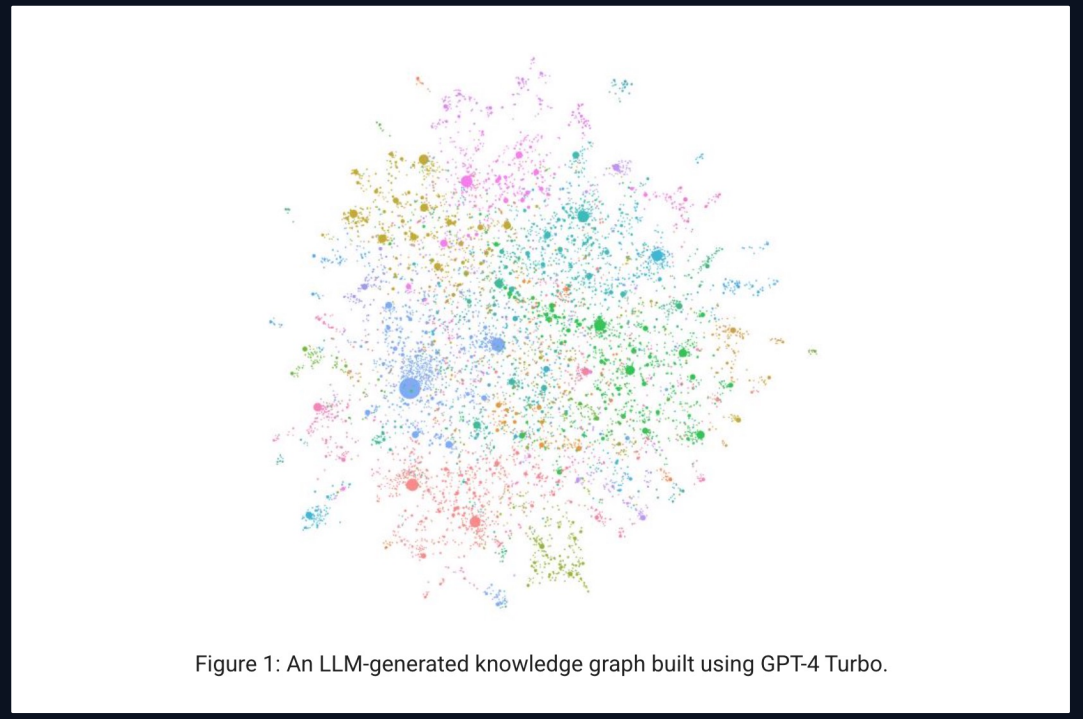


Figure 1: An LLM-generated knowledge graph built using GPT-4 Turbo.

Microsoft GraphRAG: an external example

Source: Microsoft GraphRAG documentation; left graph is illustrative

Agentic Analysis with AG2 and FastMCP



Minimal FastMCP tool example

```
from fastmcp import FastMCP
mcp = FastMCP("Security")
GUIDE = {"CWE-89": "Parameterize SQL."}
@mcp.tool
def lookup(cwe: str) -> str:
    return GUIDE.get(cwe, "Not found")
```

Bound the number of steps.
Define a stopping condition.

This tool is one component of a RAG system.

Sources: AG2; FastMCP Quickstart; LangGraph Agentic RAG

Which Approach Fits the Task?

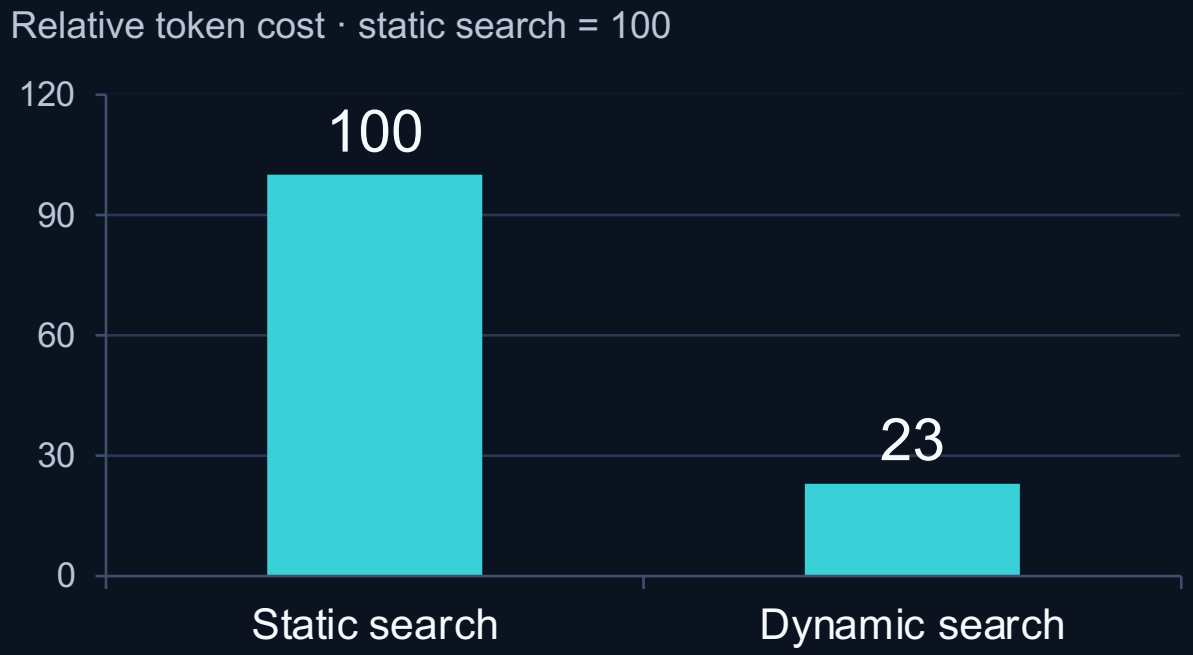
Approach	Useful when…	Additional work
Basic RAG	A few passages contain the answer.	Indexing and retrieval
GraphRAG	Facts are connected across sources.	Graph construction and updates
Agentic RAG	The next search depends on earlier results.	More decisions and tool calls

These approaches can be combined.

Sources: Microsoft GraphRAG; LangGraph retrieval documentation

When Does RAG Save Money?

Select evidence. Control model calls.



77% lower

Reported average token cost
50 AP News questions
GraphRAG global search, level 1

Total cost also includes indexing, retrieval, maintenance and review.

Experimental comparison; not measured savings for my CI module.

Evaluating an AI-Assisted Scanner

Precision

Are reported findings correct?

Recall

Are known problems detected?

Evidence

Do sources support the finding?

Cost and time

Is the workflow practical in CI?

Retrieving evidence is only the first step.

We expect the scanner to support each finding with evidence.

Sources: Vul-RAG; OWASP LLM01:2025

Conclusions

Retrieve evidence — Security knowledge gives the model useful context.

Connect context — Graphs and agents support broader analysis.

Measure the value — Validate findings, runtime and total cost.

Better retrieval. Clearer context. Reviewable findings.

Selected sources: Lewis et al. (2020) · Vul-RAG v3 (2025) · Microsoft GraphRAG
AG2 and FastMCP documentation · Full references in the speaking notes